CYBERSTER RED TEAMING

Network Enumeration & Service Vulnerability Discovery - Week 02

Name	Syed Muhammad Rayyan
Roll No	CSI-BI-620
Internship Program	Cyberster Internship
Task Title	Network Enumeration & Service Vulnerability Discovery
Target Machine	Metasploitable 2 (192.168.0.172)
Engagement Type	Active Reconnaissance & Vulnerability Scanning

1 EXECUTIVE SUMMARY

This report details the findings from Week 02 of the Cyberster Red Teaming internship. The primary objective was to transition from broad network reconnaissance to targeted scanning, service fingerprinting, and vulnerability identification. Through systematic use of Nmap, NSE scripts, and manual verification techniques, we mapped the attack surface of the Metasploitable 2 target machine. Key findings include critical backdoors in FTP and IRC services, as well as multiple web-based vulnerabilities that could lead to full system compromise.

2 TASK 01: ADVANCED NETWORK SCANNING WITH NMAP

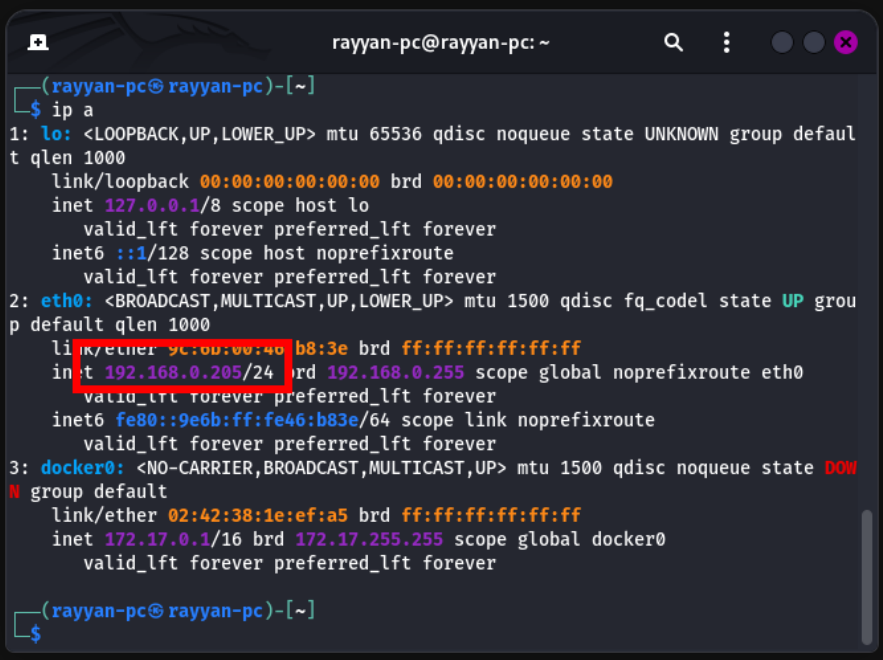
Objective: Transition from broad reconnaissance to targeted network scanning, identifying open ports and fingerprinting services while avoiding basic security triggers.

2.1 1.1 Host Discovery & Initial Setup

The foundational step of any active engagement is identifying the target's presence on the live network. We began by auditing our own network interface configuration to understand the local subnet structure and gateway routing.

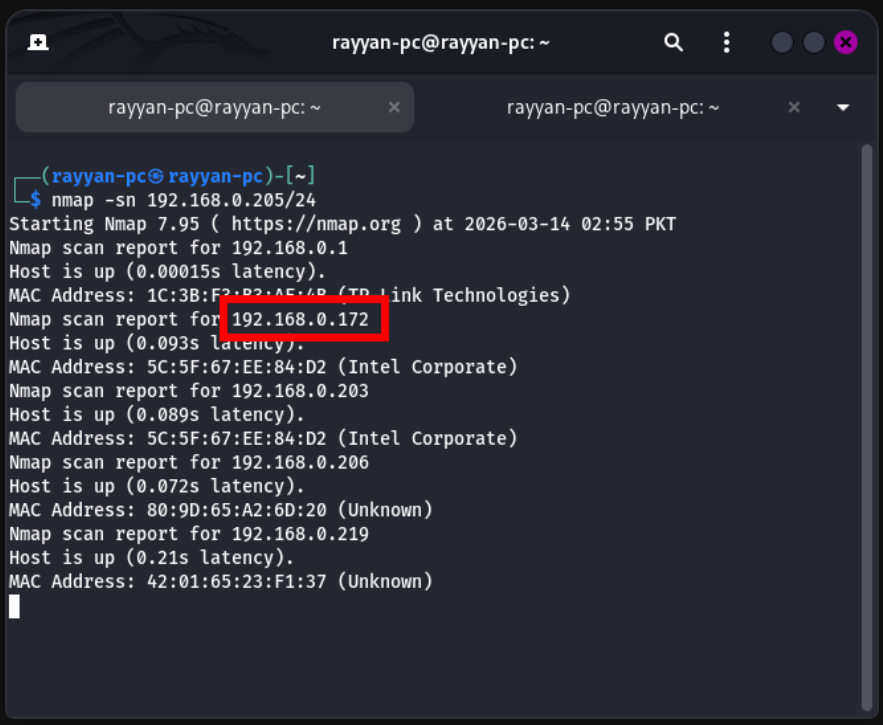
Methodology: A ping sweep (`-sn`) was performed on the local subnet. Unlike a full port scan, this method only probes whether a host is alive, making it faster and less intrusive. This allows for rapid identification of targets within a large IP pool without triggering heavy traffic alerts.

```
# Identifying local network interface
ip a
```



Step 1: Identifying local network interface and gateway configuration.

```
# Performing a ping sweep to locate the target
nmap -sn 192.168.0.205/24
```



Step 2: Subnet discovery scan to identify the target IP address (192.168.0.172).

2.2 1.2 Comparative Analysis of Scan Techniques

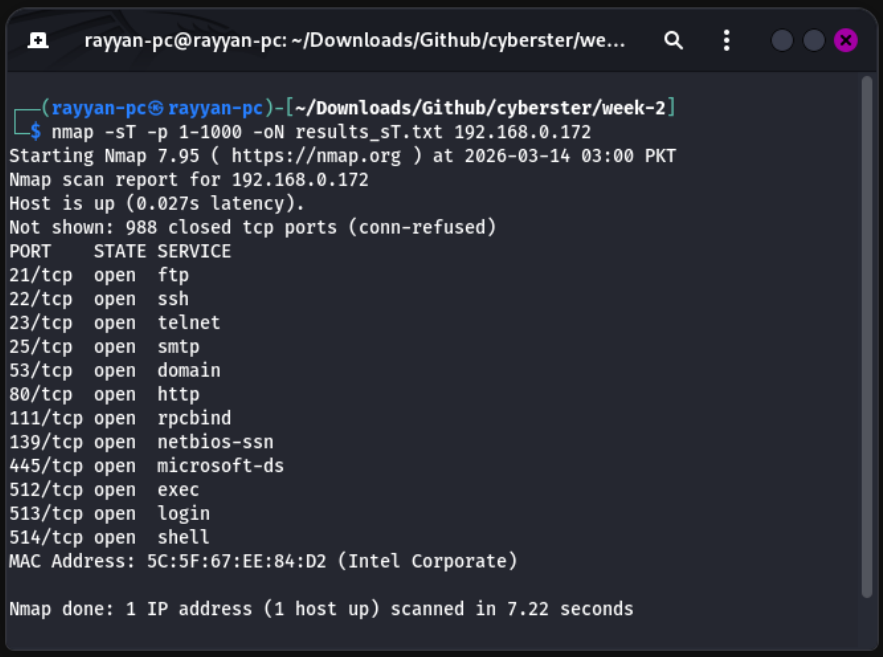
In this phase, we executed three distinct scan types to evaluate their impact on performance, accuracy, and stealth. Understanding these differences is critical for selecting the right tool for specific environments.

2.2.1 A) TCP Connect Scan (-sT)

The TCP Connect scan utilizes the operating system's `connect()` system call to complete the full 3-way handshake (SYN, SYN-ACK, ACK).

- **Interpretation:** While accurate, it is "loud" because target application logs will often record the completed connection.
- **Performance:** In our test, this scan took **7.22s**.

```
nmap -sT -p 1-1000 -oN results_sT.txt 192.168.0.172
```



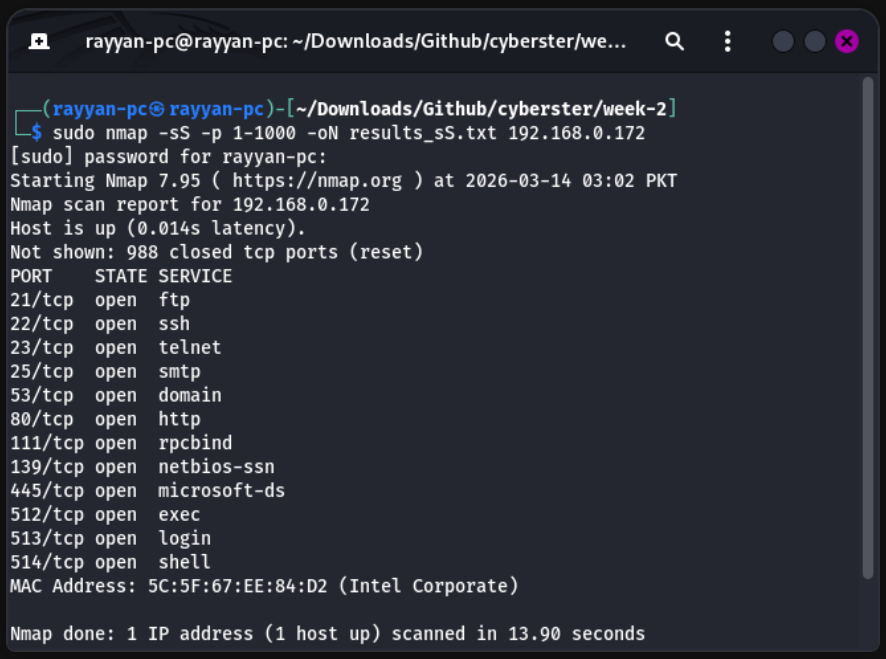
Step 3: Execution of the full TCP 3-way handshake scan.

2.2.2 B) SYN Stealth Scan (-sS)

The SYN Stealth scan teardowns the connection before it is fully established, avoiding log footprints in many application-level logs.

- **Performance:** This scan took **13.90s**.

```
sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.0.172
```



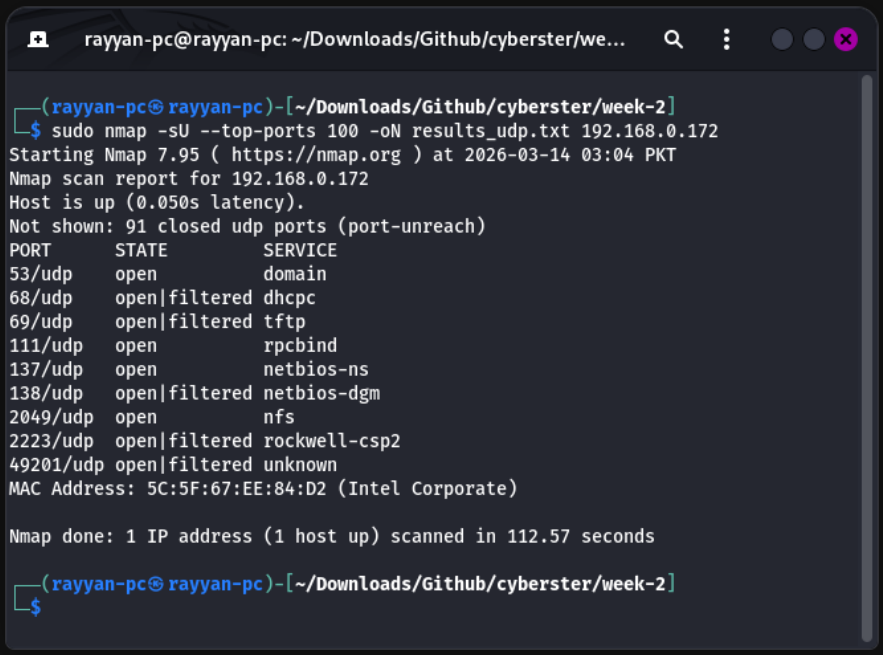
Step 4: Execution of the stealthy half-open SYN scan.

2.2.3 C) UDP Scan (-sU)

UDP scanning probes stateless ports. Since UDP does not have a handshake mechanism, it is significantly harder to scan accurately and takes longer.

- **Performance:** Scanning the top 100 ports took **12.57s**.

```
sudo nmap -sU --top-ports 100 -oN results_udp.txt 192.168.0.172
```



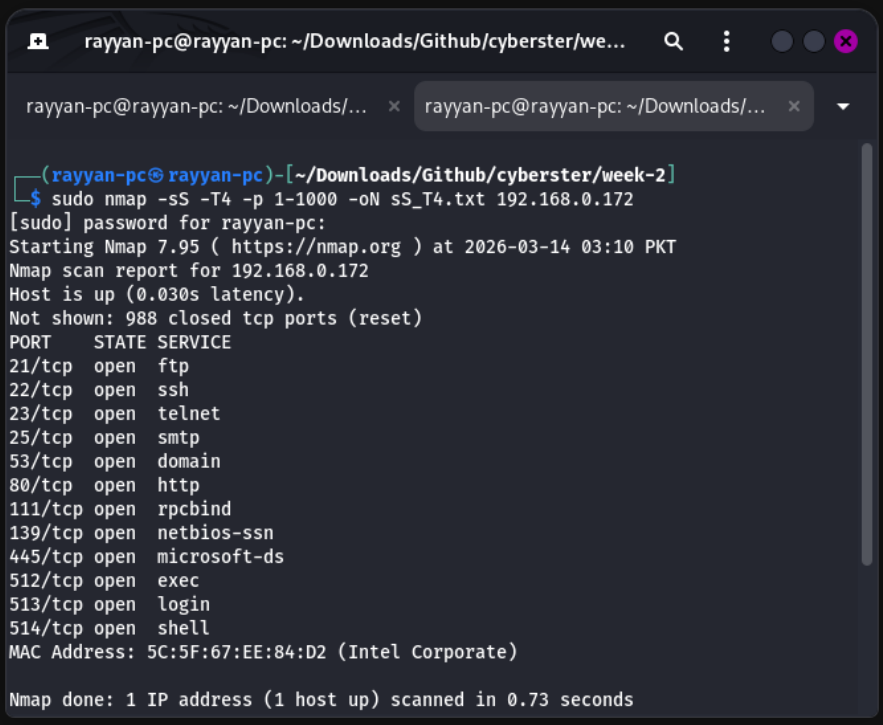
Step 5: Execution of the UDP scan for stateless services.

2.3 1.3 Timing Templates Performance

Nmap timing templates control the speed and aggressiveness of the scan.

- **Polite Template (-T2):** Used for maximum stealth to avoid triggering IDS/IPS rate-limiting. **Duration: 401.02s**.
- **Aggressive Template (-T4):** Optimized for speed on stable, modern networks. **Duration: 0.73s**.

Scan Type	Flag	Duration	Notes
TCP Connect	-sT	7.22s	Reliable, leaves footprint.
SYN Stealth	-sS	13.90s	Standard stealthy scan.
UDP Scan	-sU	12.57s	Stateless, requires patience.
Aggressive	-T4	0.73s	High speed, noisy.
Polite	-T2	401.02s	Maximum stealth, slow.



Step 8: Consolidated view of scan timings and efficiency.

3 TASK 02: SERVICE FINGERPRINTING & ATTACK SURFACE MAPPING

Objective: Identify exact software versions to map against known vulnerabilities and exploit databases.

3.1 2.1 Version Detection & Aggressive Scanning

Identifying the exact software version running on a port is critical. The `-A` flag is a "Swiss Army Knife" that enables OS Detection, Version Detection, and Script Scanning.

```
# Identify specific versions like vsFTPd 2.3.4
nmap -sV 192.168.0.172 -oN results_sV.txt
```

rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/week-2

```
┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ nmap -sV 192.168.0.172
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:18 PKT
Nmap scan report for 192.168.0.172
Host is up (0.022s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 5C:5F:67:EE:84:D2 (Intel Corporate)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; C
PE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 12.36 seconds

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$
```

```
# Full Aggressive Scan
nmap -A 192.168.0.172 -oN results_A.txt
```

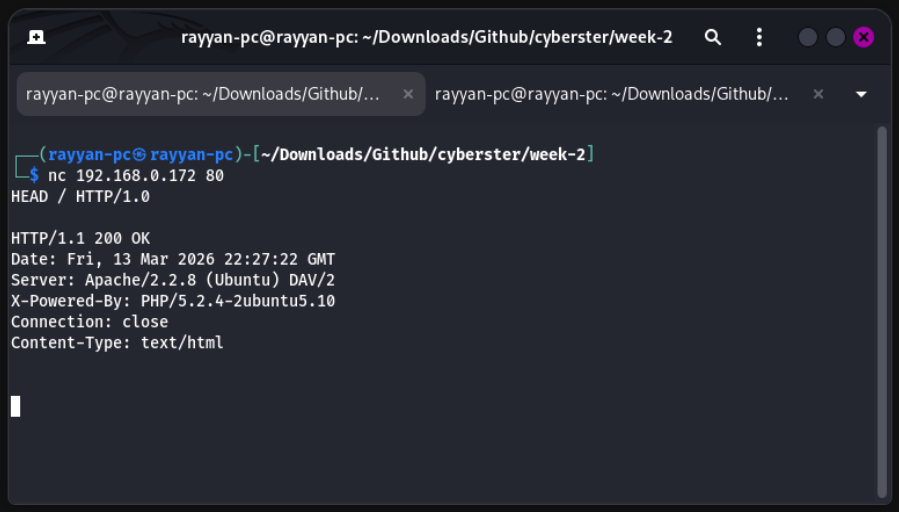
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/week-2

```
┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ nmap -A 192.168.0.172
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:21 PKT
Nmap scan report for 192.168.0.172
Host is up (0.0085s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.0.205
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_    SSL2_RC4_128_WITH_MD5
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProv
inceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
```

3.2 2.2 Manual Banner Grabbing

Manual verification using `Netcat` is essential to confirm the software and version. A banner is the initial information a server sends when a connection is established.

```
nc 192.168.0.172 80
HEAD / HTTP/1.0
```

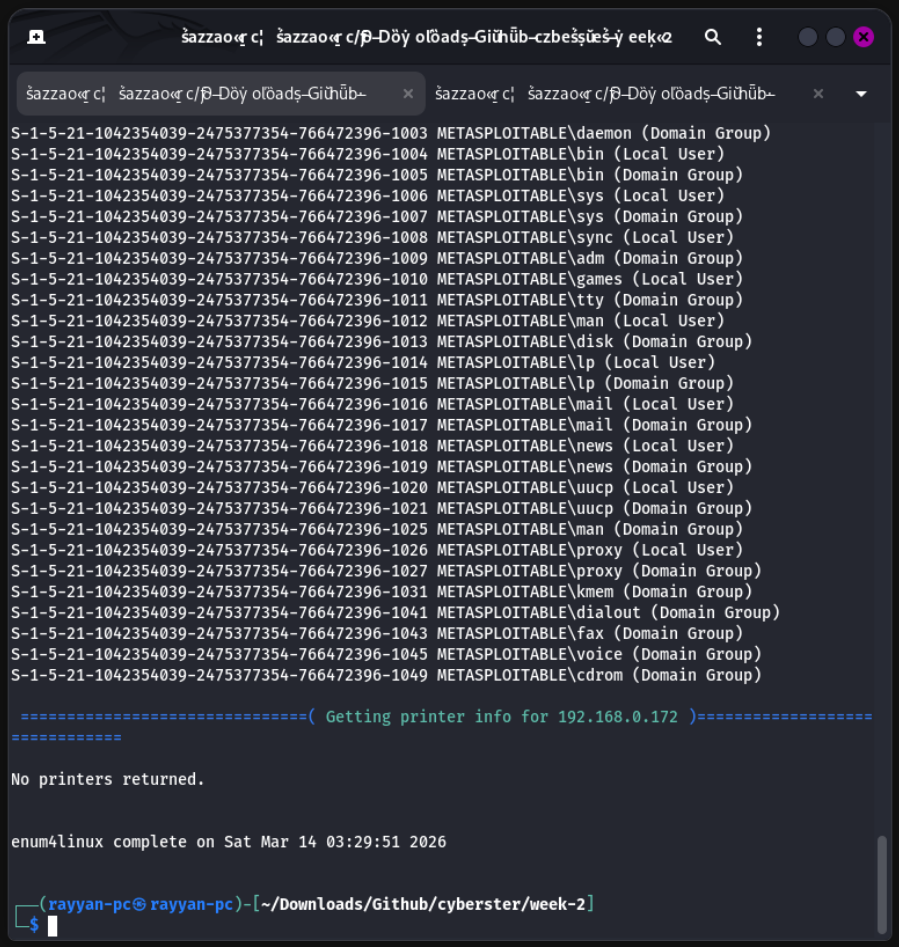


Step 11: Manually extracting the Apache web server banner via Netcat.

3.3 2.3 SMB Enumeration

Using `enum4linux`, we performed an unauthenticated scan of ports 139 and 445. This revealed that the server allows sessions with a blank username and password, allowing us to dump a list of 35 user accounts.

```
enum4linux -a 192.168.0.172
```



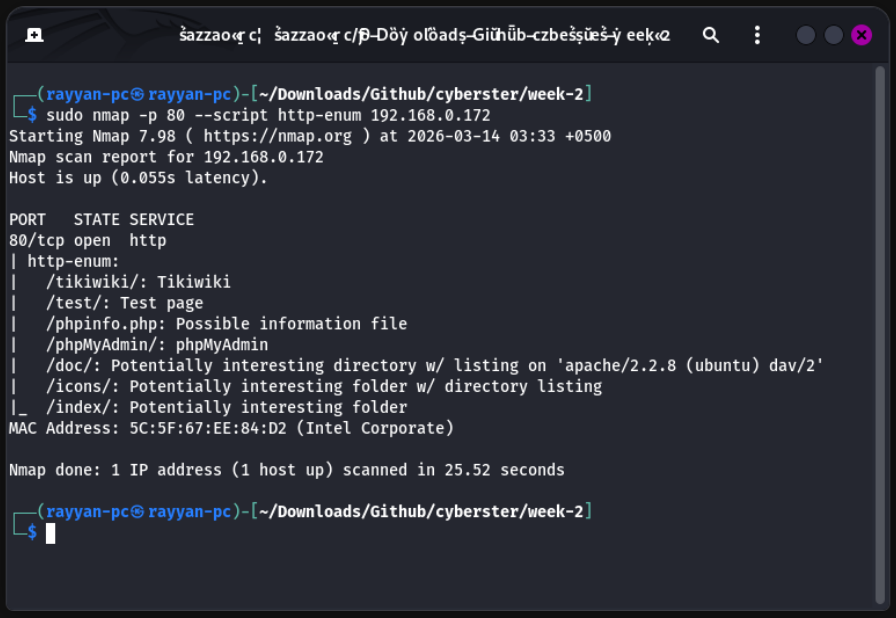
4 TASK 03: LEVERAGING NMAP SCRIPTING ENGINE (NSE)

Objective: Automate vulnerability detection using the built-in Nmap Scripting Engine categories.

4.1 3.1 HTTP Enumeration & Path Discovery

The `http-enum` script automates the discovery of sensitive directories such as `/phpinfo.php` and `/phpMyAdmin/`, which can lead to information disclosure or administrative panel exposure.

```
sudo nmap -p 80 --script http-enum 192.168.0.172
```

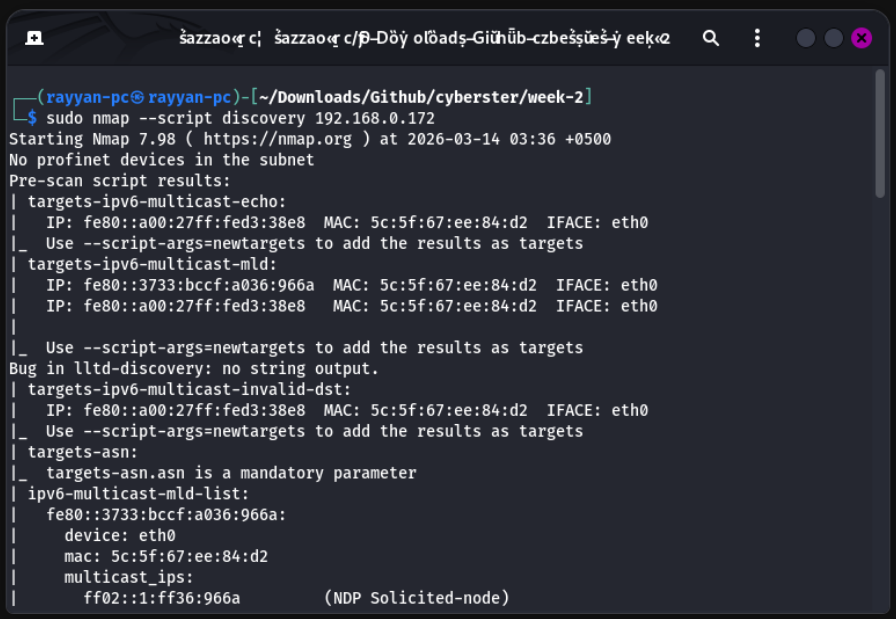


```
┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap -p 80 --script http-enum 192.168.0.172
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 03:33 +0500
Nmap scan report for 192.168.0.172
Host is up (0.055s latency).

PORT   STATE SERVICE
80/tcp open  http
| http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_  /index/: Potentially interesting folder
MAC Address: 5C:5F:67:EE:84:D2 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 25.52 seconds

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$
```

4.2 3.2 Network Discovery Scripts

The `discovery` category probes for as much information as possible about the target and its network environment, including DNS, SNMP, and SMB details.

```
sudo nmap --script discovery 192.168.0.172
```



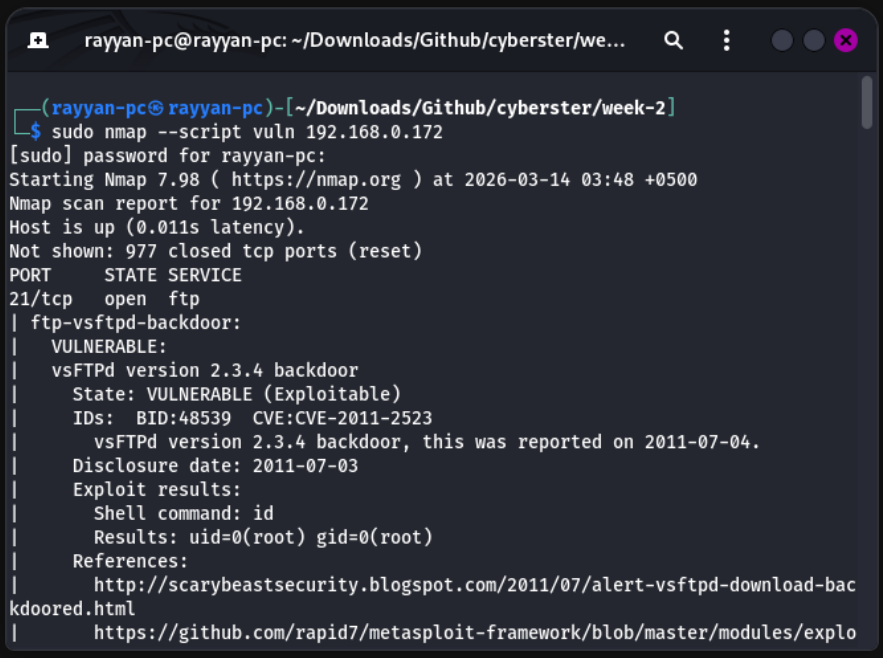
```
┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap --script discovery 192.168.0.172
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 03:36 +0500
No profinet devices in the subnet
Pre-scan script results:
| targets-ipv6-multicast-echo:
|   IP: fe80::a00:27ff:fed3:38e8  MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|_  Use --script-args=newtargets to add the results as targets
| targets-ipv6-multicast-mld:
|   IP: fe80::3733:bccf:a036:966a  MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|   IP: fe80::a00:27ff:fed3:38e8   MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|
|_  Use --script-args=newtargets to add the results as targets
Bug in lltd-discovery: no string output.
| targets-ipv6-multicast-invalid-dst:
|   IP: fe80::a00:27ff:fed3:38e8  MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|_  Use --script-args=newtargets to add the results as targets
| targets-asn:
|_  targets-asn.asn is a mandatory parameter
| ipv6-multicast-mld-list:
|   fe80::3733:bccf:a036:966a:
|     device: eth0
|     mac: 5c:5f:67:ee:84:d2
|     multicast_ips:
|       ff02::1:ff36:966a         (NDP Solicited-node)
```

4.3 3.3 Vulnerability Identification

The `vuln` category checks for specific, known exploits based on identified service versions.

Port	Service	Vulnerability	CVE ID	Risk
21	FTP	vsFTPd 2.3.4 Backdoor	CVE-2011-2523	Critical
25	SMTP	SSL POODLE	CVE-2014-3566	Medium
80	HTTP	Slowloris DoS	CVE-2007-6750	High
5432	PostgreSQL	CCS Injection	CVE-2014-0224	Medium
6667	IRC	UnrealIRCd Trojan	CVE-2010-2075	Critical
1524	Shell	Bindshell Root Access	N/A	Critical

```
sudo nmap --script vuln 192.168.0.172
```



5 TASK 04: STEALTH & FIREWALL EVASION TECHNIQUES

Objective: Employ packet manipulation and traffic masking to bypass basic network security filters.

5.1 4.1 MTU Manipulation

By using MTU Manipulation (`-mtu 16`), we force the network stack to split scan packets into smaller, non-standard sizes to evade simple signature-based packet inspection.

```
sudo nmap -sS --mtu 16 192.168.0.172
```

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap -sS --mtu 16 192.168.0.172
sh: 0: getcwd() failed: No such file or directory
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 04:07 +0500
Nmap scan report for 192.168.0.172
Host is up (0.012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
```

5.2 4.2 Decoy Scanning (-D) & Source Port Spoofing

Decoy scanning makes it appear as though multiple systems are performing the scan simultaneously. Source Port Spoofing forces Nmap to originate its scan from "trusted" ports like DNS (53).

```
sudo nmap -sS -D RND:5 192.168.0.172
sudo nmap -sS --source-port 53 192.168.0.172
```

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$  sudo nmap -sS --source-port 53 192.168.0.172
sh: 0: getcwd() failed: No such file or directory
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 04:11 +0500
Nmap scan report for 192.168.0.172
Host is up (0.019s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
```

6 ACTIONABLE INSIGHTS & CONCLUSION

The most critical findings are the **vsFTPd 2.3.4 Backdoor** and the **Unauthenticated Bind-shell**. These provide immediate root access. We recommend immediate patching of services and implementation of strict firewall rules.

Date: March 14, 2026
Classification: Training / Authorized Engagement
Report Prepared By: Syed Muhammad Rayyan (CSI-BI-620)